Nätverksdesign – Introduktion

Nätverkssäkerhet

Planering

- Anmälan för praktiskt prov finns på Canvas

Vecka	Dag	Moment
35	-	~~**Kursintroduktion**~~
	-	~~**Inspelade föreläsningar –** Internet och nätverk i våra liv, nätverksoperativsystem, konfiguration och protokoll~~
	Ons	~~**Föreläsning –** Nätverksprotokoll och standarder~~
	Tor	~~**Laboration**, förmiddag eller eftermiddag (bokas i Canvas)~~
36	-	~~**Inspelade föreläsningar –** Lager 1 (Physical), Lager 2 (Data Link)~~
	Ons	~~**Föreläsning –** Ethernet~~
	Tor	~~**Laboration**~~
37	Mån	~~**Dugga** (09.00), *görs hemifrån mellan 09.00 – 09.10* & **Inspelade föreläsningar –** Lager 3 (Network)~~
	Ons	~~**Föreläsning –** ARP & routerkonfiguration~~
	Tor	~~**Laboration**~~
	Sön	~~**Deadline Projekt 1 & Halvtidsutvärdering**~~
38	Mån	~~**Dugga** (09.00) & **Inspelade föreläsningar –** Lager 3 (forts.), IPv4~~
	Ons	~~**Föreläsning –** Subnetting~~
	Tor	~~**Laboration**~~
	Sön	~~**Deadline Projekt 2**~~
39	Mån	~~**Dugga** (09.00) & **Föreläsning (on-campus) –** IPv6~~
	-	~~**Inspelad föreläsning –** Genomgång inför praktiskt prov~~
	Tor	~~**Laboration**~~
	Sön	~~**Deadline Projekt 3**~~
40	Mån	~~**Dugga** (09.00) & **Inspelade föreläsningar –** Lager 4 (Transport), UDP & TCP~~
	Ons	~~**Föreläsning –** Lager 5-7 (Application), applikationer & tjänster~~
	Tor	~~**Laboration**~~
41	Mån	~~**Dugga** (09.00) &~~ **Inspelade föreläsningar** – Design av små nätverk
	Ons	**Föreläsning** – Nätverkssäkerhet
	Tor	**Laboration**
42	-	**Tentamen, praktiskt prov & certifikatstest**

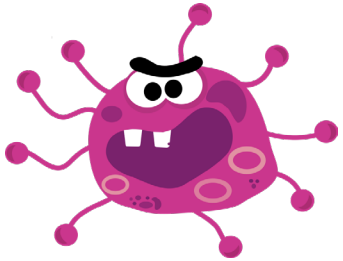
Säkerhetshot

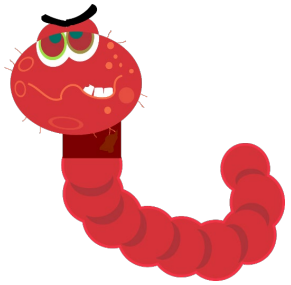
- Det finns fyra huvudsakliga säkerhetshot i nätverk (enligt Cisco):
  - **Informationsstöld**, t.ex. att hemliga information blir stulen/kopierad/avläst
  - **Förstörelse eller manipulation av data**, t.ex. ett virus som formaterar hårddisken
  - **Avbrott i en tjänst** t.ex. när man inte kan nå vissa hemsidor för att de blir överbelastade med information, Denial of Service (DoS)
  - **Identitetsstöld**, t.ex. när identiteter blir stulna för att t.ex. ändra i ett betyg i ett lärsystem, eller för att beställa något med annat namn

Svagheter/sårbarheter i nätverk

- Det finns tre huvudtyper av svagheter i nätverk
  - **Tekniska** kan vara svagheter i protokoll, exempelvis är TCP som är ett vanligt transportprotokoll helt okrypterat. Det kan även innefatta svagheter i operativsystemet, t.ex. säkerhetshål i Windows
  - **Konfigurationsmässiga** är till exempel osäkra lösenord, felkonfigurerade inställningar och osäkra standardinställningar
  - **Policymässiga** kan vara en dålig säkerhetspolicy, det kan också vara att policyn inte följs av de anställda
  - (**Informella/Sociala**) – Dålig säkerhetskultur på företaget, t.ex. användandet av osäkra lösenord
- Utifrån dessa svagheter finns det också ett antal hot:

Malware (skadlig kod)

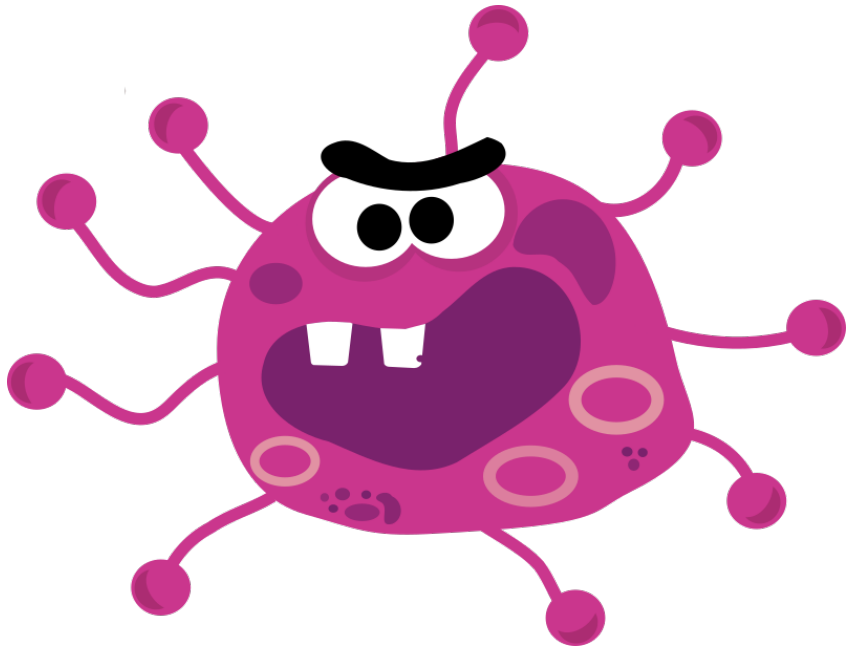




- **Malware** har tre huvudtyper:
  - **Virus**
  - **Trojanska hästar**
  - **Maskar**
- Förutom dessa finns också annan skadlig kod, t.ex. spyware, ransomware, etc.
- Finns olika definitioner och beskrivningar, i denna kurs utgår vi från boken, men var medvetna om att andra böcker kan beskriva det annorlunda

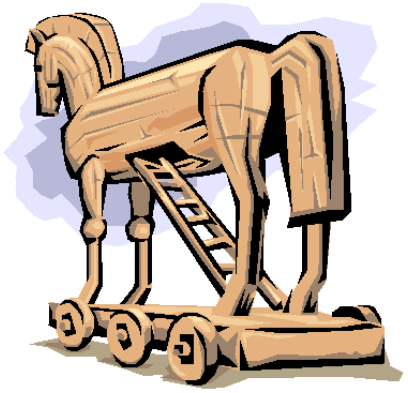
Virus

- **Virus** är skadlig kod som hänger sig fast vid andra program
- Aktiveras endast när användaren startar programmet, eller klickar på en viss fil
- Vanligaste sättet att bli infekterad är via mail
  - Hur undviker vi detta?



Trojanska hästar

- **Trojanska hästar** är kod som utger sig för att göra något annat, t.ex. en falsk inloggningsruta eller som gömd kod i nedladdade spel
- En vanligt variant är RAT (Remote Access Trojan)
- Hur undviker vi att bli infekterade?

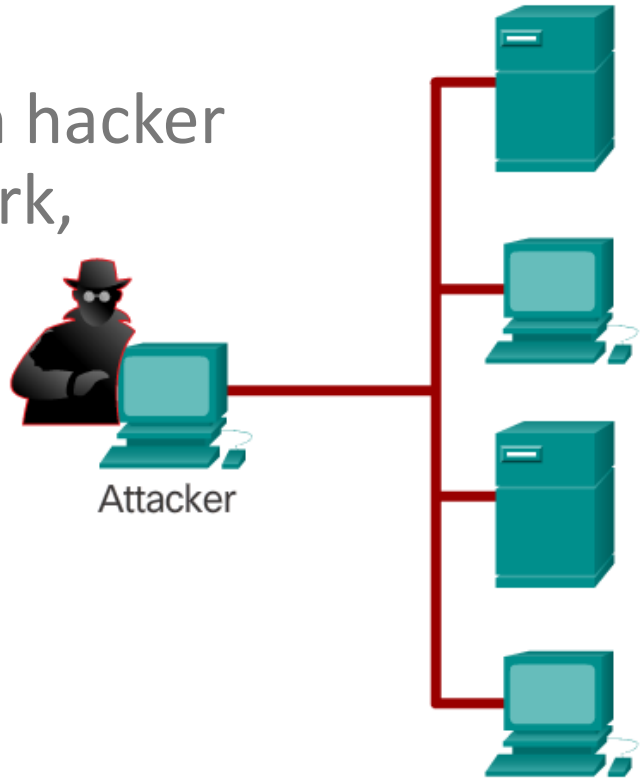


Maskar

- **Maskar** är skadlig kod som kopierar och sprider och exekverar sig själv, t.ex. via svagheter i nätverk, datorer och operativsystem
- Hur undviker vi att bli infekterade?

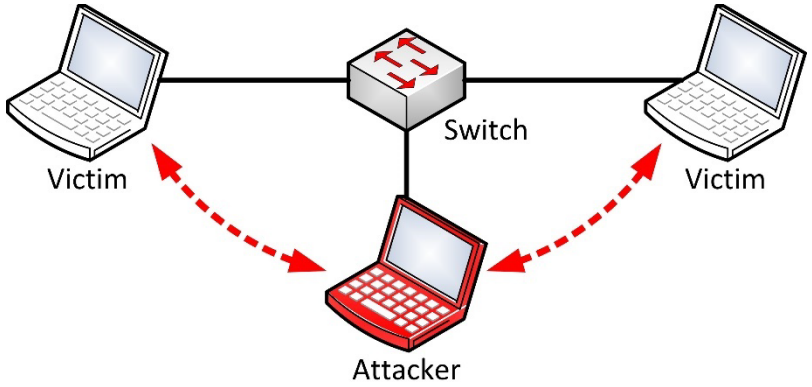
Reconnaissance-attacker

- Attacker kan också delas in i tre stora grupper; Reconnaissance-, Access- och Denial of Service-attack
- **Reconnaissance** (Rekognans)-attack innebär att en hacker samlar in så mycket data som möjlig från ett nätverk, t.ex. med:
  - WHOIS (Internet queries)
  - Ping sweeps
  - Portskanningar (nmap)
  - Paketsniffare
- I de flesta fallen helt lagligt!



Access-attacker

- **Access**-attack innebär att data stjäls eller manipuleras, det kan även innebära att en hacker får tillgång till ett system
- Exempel på access-attacker:
  - Password attack (ordlista, rainbow tables)
  - Trust exploitation
  - Man-in-the-Middle (MITM)
  - Zero day-attacker

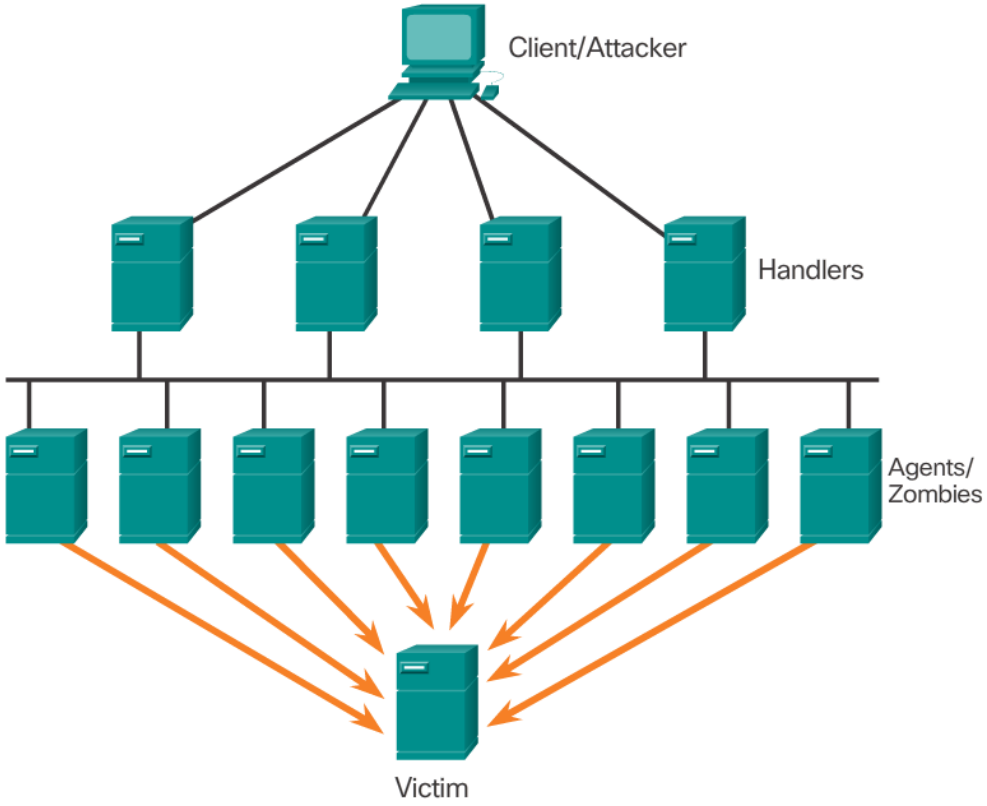


Överkurs: Exempel-attack

- Exempel-attack:
  1. Samla information om företaget via t.ex. Google (OSINT)
  2. Utför en ***ping-sweep*** mot nätverket
  3. Utför en ***portskanning*** mot nätverket
  4. Kör en ***Vulnerability Scanner*** mot nätverket, t.ex. *OpenVAS*
  5. Kör en ***Exploitation Tool*** mot en tjänst med svagheter, t.ex. via *Metasploit* (Access-attack)

Denial of Service (DoS)-attacker

- **Denial of Service** (DoS)-attack innebär att en hacker lyckas sänka ett nätverk, eller en tjänst på ett nätverk
- Vanliga metoder är bland annat:
  - En hacker skickar ett för stort eller konstigt paket
  - SYN Flood
  - DDoS



(Social engineering-attacker)

- **Social engineering** är de tekniker som används för att lura användare att ge ut information till någon som inte borde få den
  - Egentligen en typ av **access-attack**
- Kräver ingen teknisk kunskap från förövaren
- Vanliga typer av attacker:
  - Pretexting
  - Phishing
    - Spear phishing
    - Vishing
  - Tailgaiting
  - Baiting (se nästa)

Stickorna ska ha hittats i närheten av Lindholmspiren och händelsen är nu polisanmäld. Bild: Arkivbild/TT

1/3

Skadliga USB-stickor hittade på Lindholmen

GÖTEBORG På onsdagen hittades ett flertal USB-stickor med skadlig programvara på Lindholmen i Göteborg. Syftet kan ha varit att skada företagslivet i området. – Man kan eventuellt komma över känsligt material och använda det i utpressningssyfte, säger polisens presstalesperson Christer Fuxborg.

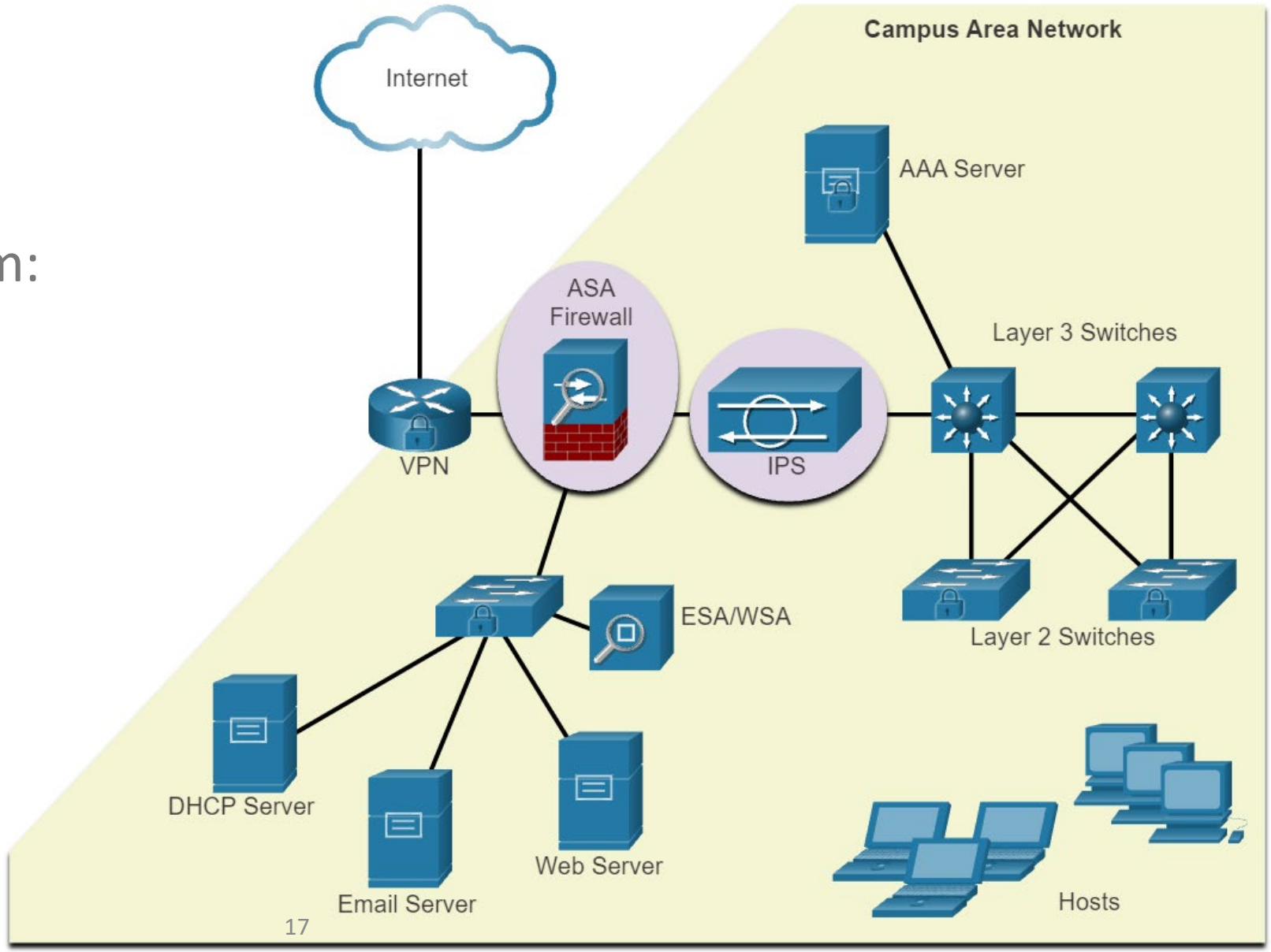
Hur skyddar vi oss?

- CIA är en utav de mest populära principerna när man pratar om **informationssäkerhet**:
  - **Confidentiality** (Konfidentialitet)
  - **Integrity** (Riktighet)
  - **Availability** (Tillgänglighet)
- Vad innebär detta rent praktiskt?

Defense-in-depth

Defense-in-depth

- I årskurs två pratar vi om:
  - Brandväggar
  - IPS
  - AAA
  - Applikationsskydd
  - L2-säkerhet
  - Endpoint-skydd
  - VPN
  - med mera…

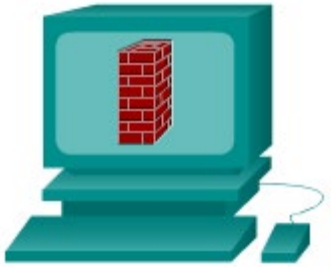


Säkra nätverket

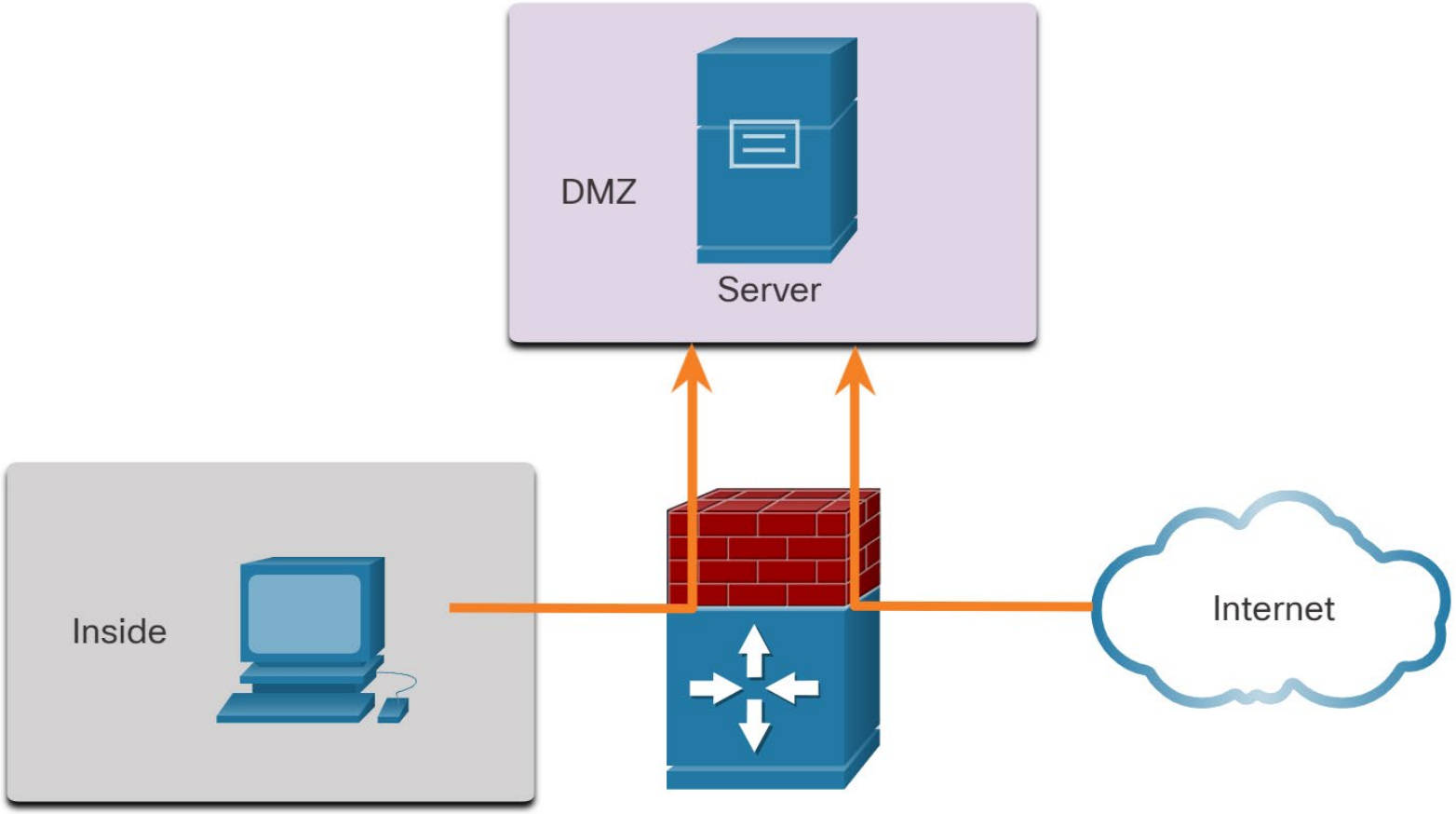
- Det mest effektiva sättet är att se till att alla enheter har **antivirus**, är **uppdaterade** och **patchade** samt har **backup**(!)
- Implementera AAA på enheter i ditt nätverk, t.ex. RADIUS
  - Authentication
  - Authorization
  - Accounting
- Glöm inte den sociala aspekten!
  - Utbilda användare
  - Uppmärksamma ovanliga händelser

Brandväggar

- Brandväggar är en utav de viktigaste enheterna för att skydda sitt nätverk. Ofta tillhandahåller de:
  - **Packet filtering**, filtrering på IP- och MAC-adresser
  - **Application filtering**, filtrering på specifika applikationer/portar
  - **URL filtering**, filtrering på specifika hemsidor
  - **Stateful packet inspection (SPI)**, endast trafik som har initierats inifrån accepteras av brandväggen
- Brandväggar kan man ha på nätverksnivå och enhetsnivå

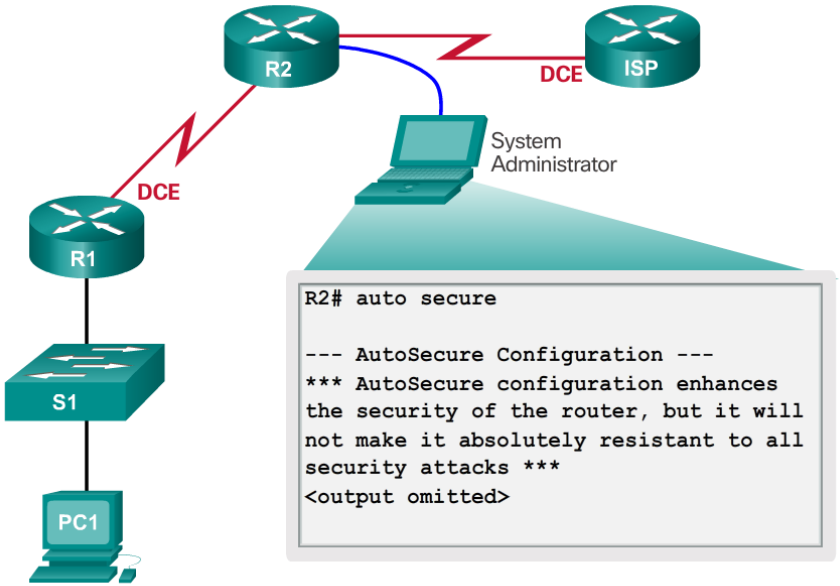


Brandväggstopologi med DMZ



Säkra upp din nätverksenhet

- Säkra lösenord
- SSH istället för Telnet
- Stäng av onödiga tjänster
- Cisco-enheter har en funktion som kallas för **auto secure**



Lösenordsregler (enligt Cisco)

- Minst 8 tecken, men gärna 10 eller mer
- Komplexa lösenord med många olika typer av tecken är bra
- Använd inte kombinationer som finns att hitta, t.ex. personnummer, husdjursnamn osv.
- Man kan försöka stava fel med olika tecken, t.ex. 5ecur1ty
- Byt lösenord ofta
- Skriv aldrig ner ditt lösenord

Strong Password	Why it is strong
b67n42d39c	Combines alphanumeric characters
12^h u4@1p7	Combines alphanumeric characters, symbols, and also includes a space

Lösenordsregler (enligt forskningen)

- 10 tecken räcker oftast inte
- Att stava ett ord fel är inte så effektivt
- Ett knep för att skapa lösenord är mnemonic-metoden
  - Yan, J., Blackwell, A., Anderson, R., & Grant, A. (2004). **Password memorability and security: Empirical results**. *IEEE Security & Privacy*, 2(5), 25-31.
- Tvinga inte användarna att byta lösenord för ofta
  - Adams, A., & Sasse, M. A. (1999). **Users are not the enemy**. *Communications of the ACM*, 42(12), 40-46
- Många lösenord? Lösenordhanterare kan hjälpa till, men var medveten om riskerna
  - Johansson, S. (2016). **Introducing Password Managers into Multiple-Password Environments**. Luleå Tekniska Universitet, Magisteruppsats

Lösenord att undvika

123456 (3.478)
12345 (1.878)
knulla (756)
qwerty (702)
666666 (689)
hejsan (587)
stilet (521)
123456789 (503)
12345678 (455)

password (437)
mamma (388)
volvo (387)
sommar (361)
hejhej (325)
niklas (316)
bajskorv (315)
gnaget (314)
artto (300)
kungen (300)

kalle (297)
sverige (291)
general (287)
kalleanka (285)
kuken (274)
123123 (258)
cocacola (249)

Lösenord på nätverksenheter

- För att säkra upp lösenord på nätverksenheter kan man göra följande:
  - Kryptera alla lösenord
  - Sätta en minimumlängd på lösenord
  - Motverka brute force-attacker
  - Korta ned tiden för inloggning

```
R1> enable
R1# configure terminal
R1(config)# service password-encryption
R1(config)# security password min-length 10
R1(config)# login block-for 120 attempts 3 within 60
R1(config)# line vty 0 4
R1(config-line)# exec-timeout 1 30
```

Använd SSH istället för Telnet

- **SSH (Secure Shell)** är som Telnet fast krypterat. Ett par delar behövs för att starta SSH på enheten:
  - Konfigurera ett domännamn
  - Generera kryptonyckel
  - Skapa användare i den lokala databasen
  - Tillåt SSH på ”line vty”
- Livelabb

```
R1> enable
R1# configure terminal
R1(config)# ip domain-name dnlab.local
R1(config)# crypto key generate rsa general-key modulus 1024
R1(config)# username sonnyfw secret cisco
R1(config)# line vty 0 4
R1(config-line)# login local
R1(config-line)# transport input ssh
R1(config-line)# exit
```

Inför praktiskt prov

- Öva, öva, öva
- Koppla upp en konsolkabel per enhet
- Skriv ned hur du kopplar!
- Glöm inte din SSD

Sista föreläsningen…

- **Stort tack för ert engagemang under kursen!**
- Har ni frågor inför tenta, praktiskt prov eller certifikatstest?

kahoot.it

JÖNKÖPING UNIVERSITY

School of Engineering